

Security+ 4.1 · Hardening Targets

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 4.1 — Hardening Targets (10:11)** · [Vídeo no YouTube ↗](#)

Resumo da Aula: Alvos: wireless (WPA2/3-Enterprise); mobile (MDM, anti-jailbreak); servers (fechar porta, remover serviço); workstations; IoT (segmentar!); ICS/OT (air gap/DMZ); cloud (IAM+SG).

Highlights que a prova cobra

- IoT (câmera, sensor): a superfície MAIS esquecida — segmentar
- ICS/OT (fábrica): air gap ou DMZ industrial

Dicas de prova & Cenários Típicos

- 'segmenting IoT devices'=security control for IoT

Cenário clássico de exame: 'câmeras IP da empresa estão na mesma VLAN que as estações de trabalho'=risky — segmentar IoT.

 **Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e**

Armadilhas da Seção 4.1)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer (Hardening Targets) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Monitoramento de Segurança (SIEM, SOAR, EDR/XDR):**
 - **SIEM:** centraliza, normaliza e correlaciona eventos de logs em tempo real para disparar alertas de segurança.
 - **SOAR:** automatiza respostas a incidentes através de playbooks coordenados, reduzindo o tempo de reação humano.
 - **EDR/XDR:** detecção e resposta a anomalias no endpoint (EDR) estendida a e-mail, nuvem e identidades (XDR).
- **Fases da Resposta a Incidentes (NIST SP 800-61 / PICERL):**
 1. **Preparação:** políticas, ferramentas, treinamentos.
 2. **Identificação/Detecção:** triagem de alertas e confirmação do incidente.
 3. **Contenção:** isolamento do sistema afetado para impedir propagação (sem destruir provas).
 4. **Erradicação:** remoção de malwares, fechamento de brechas e contas comprometidas.
 5. **Recuperação:** restauração segura dos serviços a partir de backups limpos e validação de produção.
 6. **Lições Aprendidas:** reunião pós-incidente e melhorias nos playbooks.
- **Forense Digital e Ordem de Volatilidade (RFC 3227):** Durante a coleta de evidências forenses, os artefatos mais voláteis (que somem ao desligar) devem ser capturados primeiro:
 1. Registradores da CPU e memória Cache.
 2. Memória RAM (volátil: contém senhas em claro, chaves criptográficas em uso e conexões ativas).
 3. Estado das conexões de rede e processos em execução.
 4. Sistema de arquivos e discos rígidos (HD/SSD).
 5. Mídias ópticas e backups externos arquivados.

⚠ **Armadilhas e Pegadinhas Clássicas da Banca:**

- NUNCA desligue ou reinicie um servidor comprometido antes de realizar o dump forense da memória RAM; reiniciar destrói evidências essenciais de malwares fileless.
- Qualquer manipulação de evidência digital exige cálculo imediato de hash (SHA-256) e registro rigoroso da Cadeia de Custódia (Chain of Custody).

✓ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

1. Sub-rede isolada que expõe servidores públicos (web/email) protegendo a rede interna é a:

- A)** VLAN de voz
- B)** DMZ (screened subnet)
- C)** VPN
- D)** Intranet

2. Isolar FISICAMENTE um sistema crítico da rede (sem nenhuma conexão):

- A)** Air gap
- B)** VLAN
- C)** VPN
- D)** NAT

3. Cenário corporativo (Hardening Targets): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.1), um analista avalia o seguinte requisito técnico: 'IoT (câmera, sensor): a superfície MAIS esquecida — segmentar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: IoT (câmera, sensor): a superfície MAIS esquecida — segmentar...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Hardening Targets): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.1), um analista avalia o seguinte requisito técnico: 'ICS/OT (fábrica): air gap ou DMZ industrial'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: ICS/OT (fábrica): air gap ou DMZ industrial...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Hardening Targets): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.1), um analista avalia o seguinte requisito técnico: 'segmenting IoT devices'=security control for IoT'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'segmenting IoT devices'=security control for IoT...

6. Cenário corporativo (Hardening Targets): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.1), um analista avalia o seguinte requisito técnico: 'câmeras IP da empresa estão na mesma VLAN que as estações de trabalho'=risky — segmentar IoT.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'câmeras IP da empresa estão na mesma VLAN que as estações de trabalho'=ris...

7. Cenário corporativo (Hardening Targets): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.1), um analista avalia o seguinte requisito técnico: 'IoT (câmera, sensor): a superfície MAIS esquecida — segmentar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: IoT (câmera, sensor): a superfície MAIS esquecida — segmentar...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Hardening Targets): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.1), um analista avalia o seguinte requisito técnico: 'ICS/OT (fábrica): air gap ou DMZ industrial'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: ICS/OT (fábrica): air gap ou DMZ industrial...

9. Cenário corporativo (Hardening Targets): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.1), um analista avalia o seguinte requisito técnico: 'segmenting IoT devices'=security control for IoT'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'segmenting IoT devices'=security control for IoT...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Hardening Targets): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.1), um analista avalia o seguinte requisito técnico: "câmeras IP da empresa estão na mesma VLAN que as estações de trabalho"=risky — segmentar IoT.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'câmeras IP da empresa estão na mesma VLAN que as estações de trabalho'=ris...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

1) B — DMZ (screened subnet).

✓ **Por que está certa:** DMZ / screened subnet fica entre a internet e a rede interna: o que precisa ser público mora lá, e um comprometimento não alcança direto o interno.

✗ **Por que as outras estão erradas:**

- *VLAN de voz:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *VPN:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Intranet:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

2) A — Air gap.

✓ **Por que está certa:** Air gap = zero conexão de rede (sistemas ultra-críticos, ICS). Troca de dados vira manual/mídia — o que também tem risco (USB).

✗ **Por que as outras estão erradas:**

- *VLAN:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *VPN:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *NAT:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

3) C — Implementar a solução correspondente: IoT (câmera, sensor): a superfície MAIS esquecida — segmentar....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.1 (Hardening Targets): IoT (câmera, sensor): a superfície MAIS esquecida — segmentar.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) C — Implementar a solução correspondente: ICS/OT (fábrica): air gap ou DMZ industrial....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.1 (Hardening Targets): ICS/OT (fábrica): air gap ou DMZ industrial.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) D — Implementar a solução correspondente: 'segmenting IoT devices'=security control for IoT....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.1 (Hardening Targets): 'segmenting IoT devices'=security control for IoT.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) D — Implementar a solução correspondente: 'câmeras IP da empresa estão na mesma VLAN que as estações de trabalho'=ris....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.1 (Hardening Targets): 'câmeras IP da empresa estão na mesma VLAN que as estações de trabalho'=risky — segmentar IoT..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) A — Implementar a solução correspondente: IoT (câmera, sensor): a superfície MAIS esquecida — segmentar....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.1 (Hardening Targets): IoT (câmera, sensor): a superfície MAIS esquecida — segmentar.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são

controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) D — Implementar a solução correspondente: ICS/OT (fábrica): air gap ou DMZ industrial....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.1 (Hardening Targets): ICS/OT (fábrica): air gap ou DMZ industrial.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) B — Implementar a solução correspondente: 'segmenting IoT devices'=security control for IoT....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.1 (Hardening Targets): 'segmenting IoT devices'=security control for IoT.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) A — Implementar a solução correspondente: 'câmeras IP da empresa estão na mesma VLAN que as estações de trabalho'=ris....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.1 (Hardening Targets): 'câmeras IP da empresa estão na mesma VLAN que as estações de trabalho'=risky — segmentar IoT..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.